Scansione dei Servizi con Nmap

Report esercizio W11D1 — Tecniche di scansione con Nmap su target Metasploitable

1. Topologia di rete

La scansione è stata effettuata rispettando il requisito di separazione tra macchina attaccante e macchina target su due reti distinte, interconnesse tramite un router pfSense.

Indirizzo IP target	192.168.51.101 (Metasploitable2)
Indirizzo IP attaccante	192.168.50.100 (Kali Linux)
Sistema Operativo rilevato	Nessun match esatto nel database Nmap. Fingerprint TCP/IP compatibile con Linux (architettura x86_64); coerente con Ubuntu 8.04 (base nota di Metasploitable2).
Porte aperte	23 porte TCP aperte su 1000 analizzate (elenco completo in tabella successiva)
Network Distance	2 hop (traffico instradato attraverso il router pfSense)

Configurazione delle interfacce di rete:

- Rete "kali-net" (LAN pfSense, 192.168.50.0/24) → collegata a Kali Linux (attaccante)
- Rete "pfsense" (OPT1 pfSense, 192.168.51.0/24) → collegata a Metasploitable2 (target)

pfSense funge da router tra i due segmenti, garantendo che il traffico tra attaccante e target attraversi un dispositivo di instradamento intermedio (confermato dal valore "Network Distance: 2 hops" restituito da Nmap).

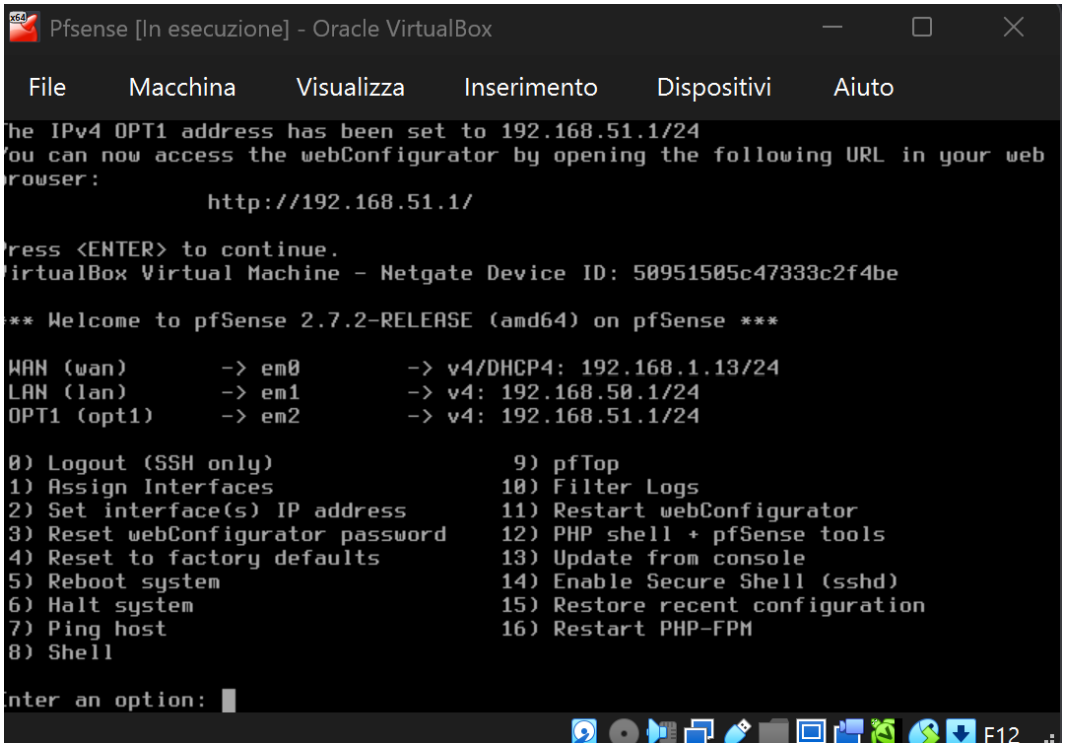


Fig. 1 — Configurazione delle interfacce su pfSense (WAN, LAN 192.168.50.1/24, OPT1 192.168.51.1/24)

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::9cd3:b605:eddb:a01b/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: eth1: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000
    link/ether 08:00:27:20:40:95 brd ff:ff:ff:ff:ff:ff
```

Fig. 2 — Output di "ip a" su Kali Linux: IP 192.168.50.100/24 su eth0

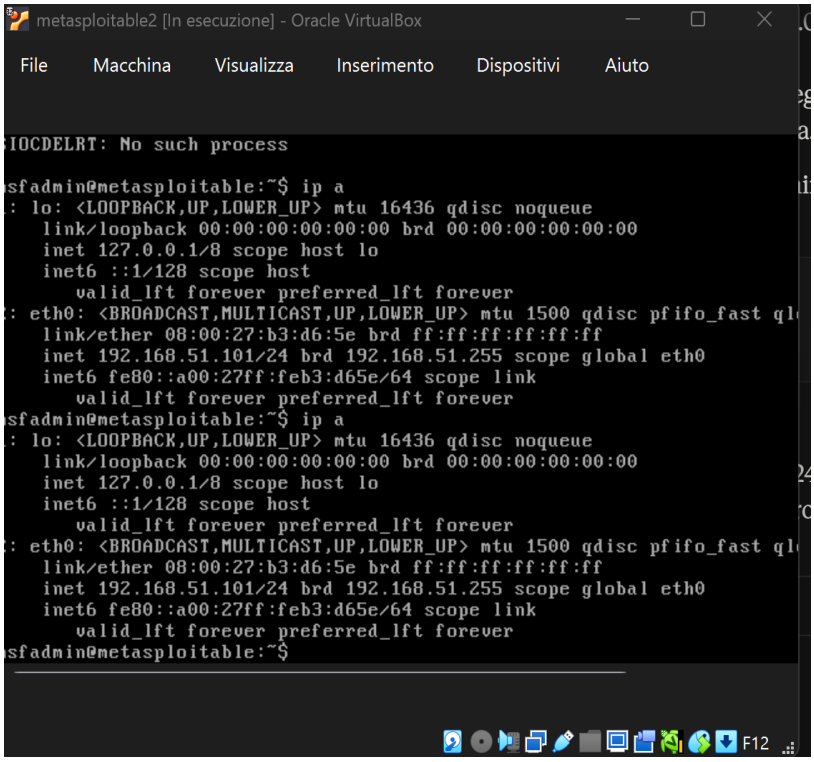


Fig. 3 — Output di "ip a" su Metasploitable2: IP 192.168.51.101/24 su eth0

2. Scansioni effettuate

2.1 OS Fingerprint

Comando utilizzato:

```
nmap -O 192.168.51.101
```

Nmap non ha individuato una corrispondenza esatta nel proprio database delle firme OS, restituendo però un fingerprint TCP/IP dettagliato. L'assenza di match esatto è comune con sistemi operativi datati come quello di Metasploitable2 (basato su Ubuntu 8.04), il cui stack di rete non è ben rappresentato nel database di Nmap. Il valore "Network Distance: 2 hops" conferma il passaggio del traffico attraverso pfSense.

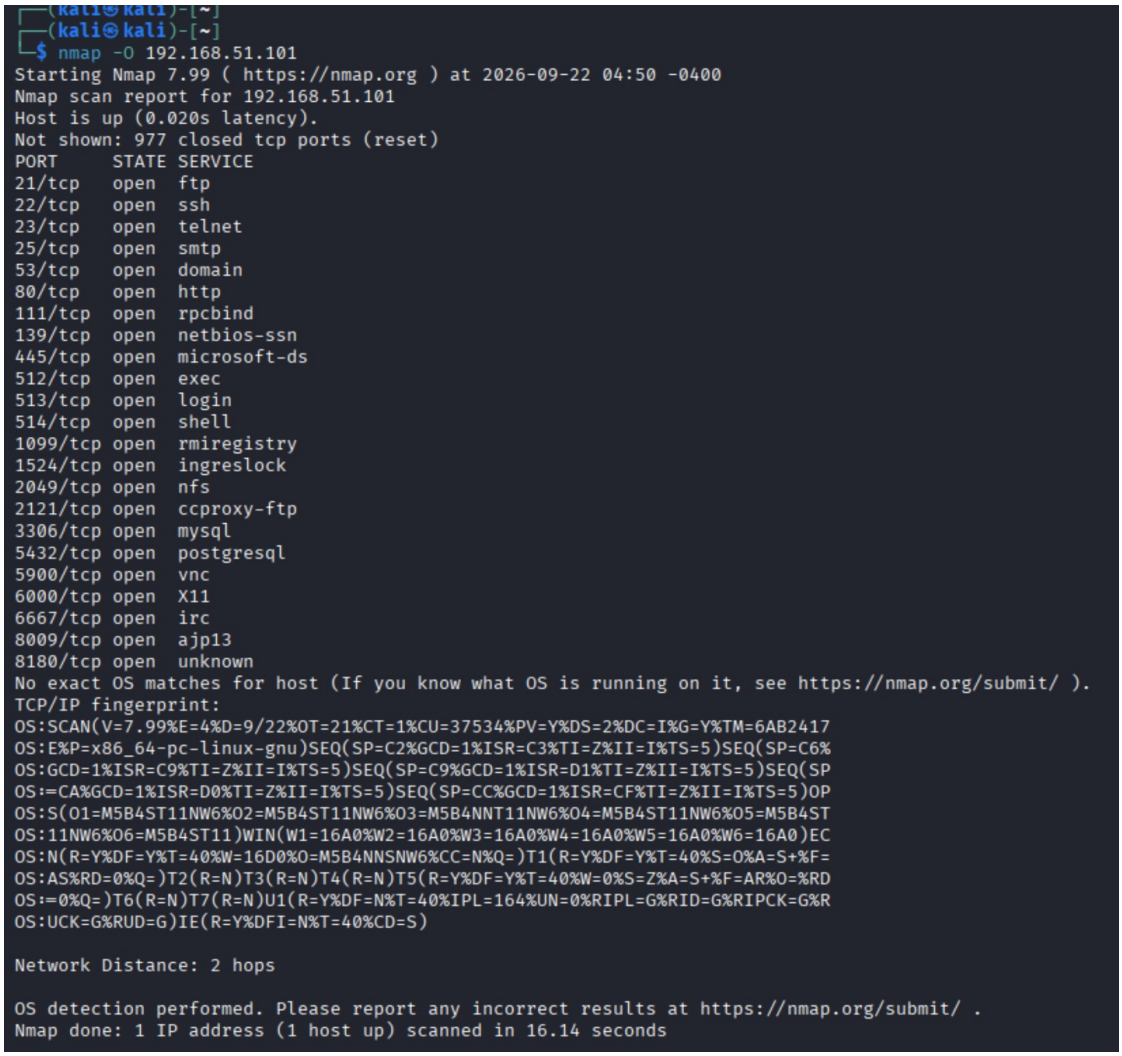


Fig. 4 — Output del comando "nmap -O"

2.2 SYN Scan

Comando utilizzato:

```
nmap -sS 192.168.51.101
```

Tecnica di scansione "stealth": Nmap invia un pacchetto SYN e osserva la risposta senza completare l'handshake TCP a 3 vie (nessun ACK finale, la connessione non si stabilisce mai realmente). Richiede privilegi elevati per costruire pacchetti raw. Rilevate 23 porte aperte in 3.02 secondi.

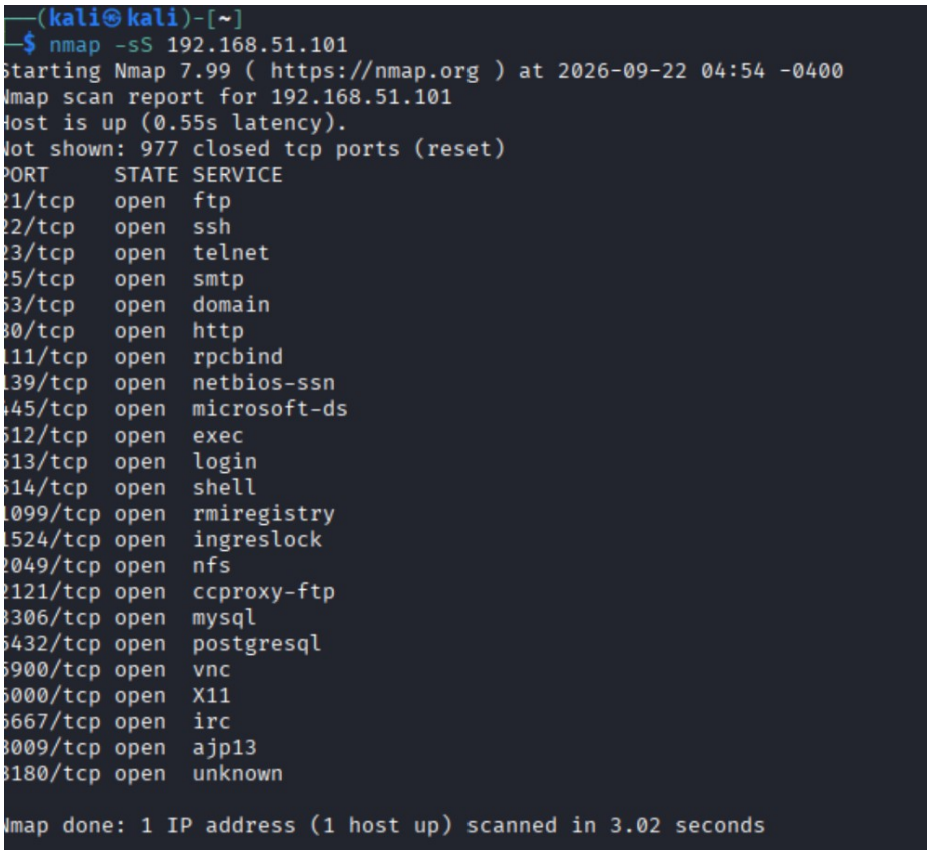


Fig. 5 — Output del comando "nmap -sS"

2.3 TCP Connect Scan

Comando utilizzato:

```
nmap -sT 192.168.51.101
```

A differenza del SYN scan, questa tecnica completa l'handshake TCP a 3 vie utilizzando le normali chiamate di sistema (connect()) del sistema operativo, aprendo e chiudendo connessioni reali verso ciascuna porta. Non richiede privilegi elevati. Rilevate le stesse 23 porte aperte in 3.13 secondi.

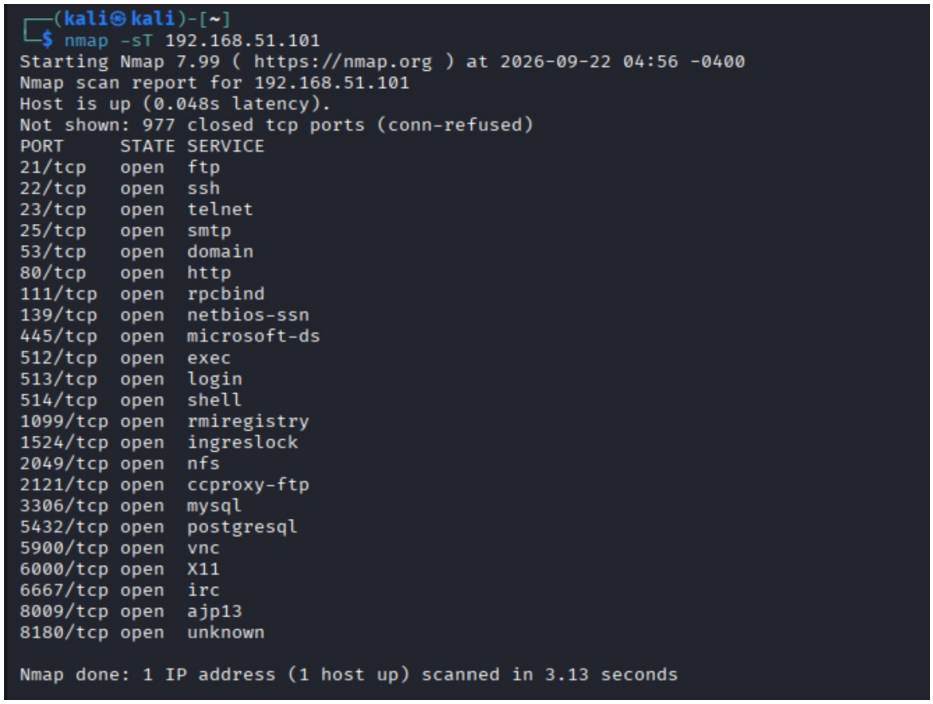


Fig. 6 — Output del comando "nmap -sT"

2.4 Confronto SYN Scan vs TCP Connect Scan

La traccia richiede di individuare eventuali differenze tra le due tecniche. Il confronto è riassunto nella tabella seguente:

Caratteristica	SYN Scan (-sS)	TCP Connect (-sT)
Porte aperte rilevate	23 (identiche)	23 (identiche)
Tempo di scansione	3.02 secondi	3.13 secondi
Handshake TCP	Parziale (SYN → SYN/ACK → RST)	Completo (SYN → SYN/ACK → ACK)
Dicitura porte chiuse	closed (reset)	closed (conn-refused)
Privilegi richiesti	Root / CAP_NET_RAW	Nessuno (socket standard OS)
Tracciabilità nei log del target	Bassa (connessione mai completata)	Alta (connessione reale, loggata dai servizi)

In termini di risultato (porte aperte rilevate), le due scansioni sono identiche: entrambe individuano le stesse 23 porte con lo stesso stato. Le differenze reali riguardano il meccanismo di funzionamento:

- Il SYN scan non completa mai la connessione TCP (invia RST dopo aver ricevuto SYN/ACK), risultando meno invasivo e meno tracciabile dai log applicativi del target.
- Il TCP connect scan stabilisce connessioni reali e complete, che possono essere registrate nei log dei singoli servizi in ascolto sul target (es. log di autenticazione SSH, log di Apache, ecc.).
- Il SYN scan richiede privilegi di root (o capability CAP_NET_RAW), mentre il TCP connect scan può essere eseguito da un utente non privilegiato.
- Su questa rete locale di piccole dimensioni i tempi di esecuzione sono praticamente equivalenti; la differenza di velocità tra le due tecniche diventa più marcata su scansioni estese (molte porte e/o molti host).

2.5 Version Detection

Comando utilizzato:

```
nmap -sV 192.168.51.101
```

La scansione con rilevamento versione interroga attivamente ciascun servizio in ascolto per identificarne il software e la versione esatta, informazione fondamentale per la successiva ricerca di vulnerabilità note (CVE).

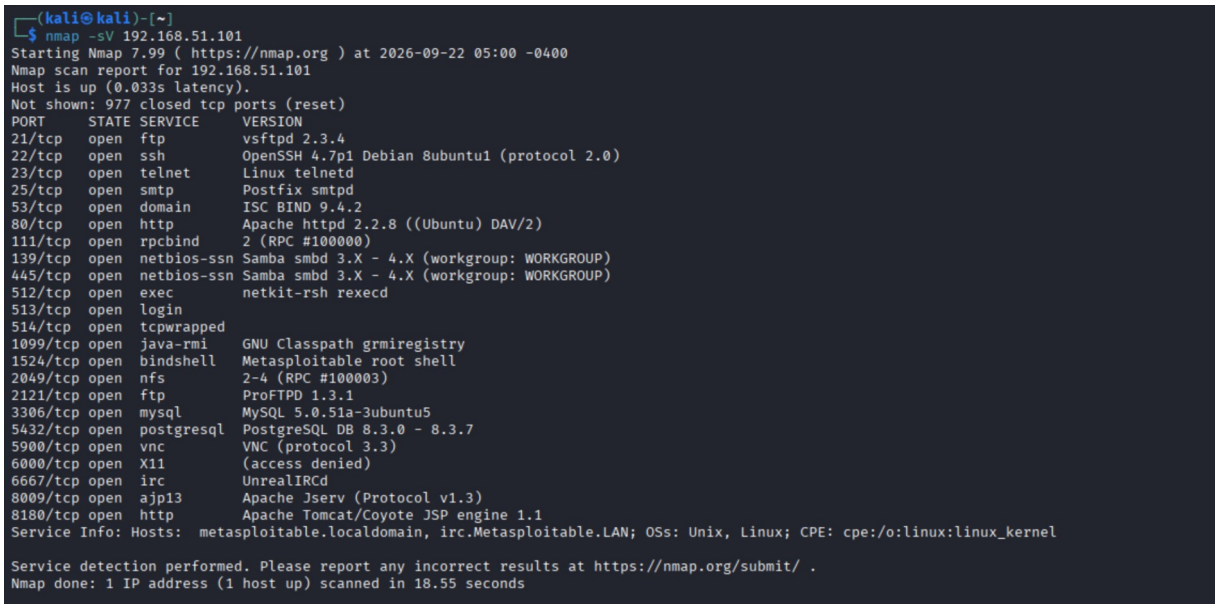


Fig. 7 — Output del comando "nmap -sV"

3. Report riepilogativo

Di seguito la sintesi di tutte le informazioni raccolte, come richiesto dalla traccia.

3.1 Informazioni host

Indirizzo IP target	192.168.51.101 (Metasploitable2)
Indirizzo IP attaccante	192.168.50.100 (Kali Linux)
Sistema Operativo rilevato	Nessun match esatto nel database Nmap. Fingerprint TCP/IP compatibile con Linux (architettura x86_64); coerente con Ubuntu 8.04 (base nota di Metasploitable2).
Porte aperte	23 porte TCP aperte su 1000 analizzate (elenco completo in tabella successiva)
Network Distance	2 hop (traffico instradato attraverso il router pfSense)

3.2 Porte aperte, servizi e versioni

Porta	Servizio	Versione	Descrizione
21	ftp	vsftpd 2.3.4	Server FTP — versione nota per la backdoor CVE-2011-2523 (accesso root da username contenente ":)")
22	ssh	OpenSSH 4.7p1 Debian 8ubuntu1	Servizio SSH per accesso remoto sicuro; versione datata con vulnerabilità note
23	telnet	Linux telnetd	Accesso remoto in chiaro (credenziali e traffico non cifrati)
25	smtp	Postfix smtpd	Server di posta elettronica (invio email)
53	domain	ISC BIND 9.4.2	Server DNS per la risoluzione dei nomi
80	http	Apache httpd 2.2.8 (Ubuntu) DAV/2	Web server con supporto WebDAV abilitato
111	rpcbind	RPC #100000	Mappatura dei servizi RPC (Remote Procedure Call)
139	netbios-ssn	Samba smbd 3.X-4.X	Condivisione file/stampanti in stile Windows (NetBIOS)
445	microsoft-ds	Samba smbd 3.X-4.X	Condivisione SMB diretta su TCP
512	exec	netkit-rsh rexecd	Esecuzione comandi remoti (protocollo r-services, non sicuro)
513	login	—	Login remoto (rlogin), protocollo r-services
514	shell	tcpwrapped	Shell remota (rsh), protocollo r-services
1099	java-rmi	GNU Classpath grmiregistry	Registro RMI Java, storicamente vulnerabile a exploit di deserializzazione
1524	bindshell	Metasploitable root shell	Shell di root lasciata volutamente aperta (backdoor didattica di Metasploitable)
2049	nfs	RPC #100003	Condivisione file di rete NFS
2121	ftp	ProFTPD 1.3.1	Secondo server FTP in ascolto, versione con vulnerabilità note
3306	mysql	MySQL 5.0.51a-3ubuntu5	Database MySQL, versione obsoleta

Porta	Servizio	Versione	Descrizione
5432	postgresql	PostgreSQL DB 8.3.0-8.3.7	Database PostgreSQL, versione obsoleta
5900	vnc	VNC (protocol 3.3)	Accesso desktop remoto, protocollo datato
6000	X11	(access denied)	Server grafico X11, accesso negato in fase di rilevamento
6667	irc	UnrealIRCd	Server IRC — versione storicamente affetta da backdoor nota
8009	ajp13	Apache Jserv (Protocol v1.3)	Connettore AJP tra Apache e Tomcat
8180	http	Apache Tomcat/Coyote JSP engine 1.1	Application server Tomcat per applicazioni Java/JSP

4. Conclusioni

La scansione ha evidenziato un numero elevato di servizi esposti e per la maggior parte basati su versioni software datate, coerentemente con la natura didattica di Metasploitable2 (piattaforma intenzionalmente vulnerabile). Tra i punti più critici rilevati:

- vsftpd 2.3.4 (porta 21) — versione nota per una backdoor che consente accesso root
- UnrealIRCd (porta 6667) — versione storicamente affetta da una backdoor nel codice sorgente
- Bindshell root (porta 1524) — shell di root accessibile senza autenticazione
- Servizi r-services (rexec, rlogin, rsh — porte 512-514) — protocolli obsoleti privi di cifratura
- Telnet (porta 23) — trasmissione delle credenziali in chiaro

La topologia a due reti separate con pfSense come router intermedio ha permesso di svolgere le scansioni in uno scenario realistico, in cui attaccante e target non si trovano sullo stesso segmento di rete.